

MODULO 3

***PRÁCTICA N1->**

“Hacking de servidores web”

1. Introducción y Objetivo

El objetivo de esta práctica es realizar un reconocimiento y extracción de información del servidor web

<http://www.tokiohacking.com/>.

Como hackers éticos, nuestra misión es identificar vulnerabilidades y

configuraciones incorrectas para proporcionar seguridad a la empresa.

2. Técnicas Seleccionadas

Para este informe se han combinado dos de las técnicas propuestas en la práctica:

-Técnica 5: Huella de un servidor web usando Netcat y Telnet.

-Técnica 6: Enumeración de información usando Nmap Scripting Engine (NSE).

3. Fase 1: Reconocimiento con Nmap (NSE)

Procedimiento: Se utilizó Nmap con scripts especializados (http-headers, http-enum, etc.) para auditar los puertos abiertos 80 (HTTP) y 443 (HTTPS).

Análisis de la Captura:

Servidor Identificado: Apache.

Hallazgo relevante: El script http-headers confirmó que el servidor responde a peticiones GET directas revelando su software base.

Justificación: El uso de NSE permite una verificación rápida de fallas de seguridad sin parches y configuraciones incorrectas de manera automatizada.

```
(kali@kali)-[~]
$ nmap -p80,443 --script http-enum,http-headers,http-methods,http-robots.txt,http-auth-finder 31.214.178.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-17 20:37 +0100
Nmap scan report for hostingsrv18.dondominio.com (31.214.178.4)
Host is up (0.0063s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-headers:
|   Date: Tue, 17 Feb 2026 19:37:18 GMT
|   Server: Apache
|   Content-Length: 199
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|_ (Request type: GET)
443/tcp   open  https
| http-headers:
|   Date: Tue, 17 Feb 2026 19:37:18 GMT
|   Server: Apache
|   Content-Length: 199
|   Connection: close
|   Content-Type: text/html; charset=iso-8859-1
|_ (Request type: GET)

Nmap done: 1 IP address (1 host up) scanned in 162.95 seconds
```

4. Fase 2: Huella Manual (Netcat y Telnet)

Procedimiento: Ante la detección inicial de servicios protegidos (tcpwrapped), se optó por una conexión manual por IP (31.214.178.4) para forzar el "Banner Grabbing".

Análisis de los Resultados:

Netcat: Aunque devolvió un error "400 Bad Request", la cabecera del error reveló el servidor **Apache**.

```
(kali@kali)-[~]
$ nc -v 31.214.178.4 80
hostingsrv18.dondominio.com [31.214.178.4] 80 (http) open
HEAD / HTTP/1.0
HTTP/1.1 400 Bad Request
Date: Tue, 17 Feb 2026 19:32:20 GMT
Server: Apache
Content-Length: 226
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
</body></html>
```

Telnet: Se obtuvo una respuesta "200 OK" exitosa. Se identificó el soporte para el protocolo HTTP/2 (h2, h2c) y la fecha de última modificación del contenido.

```
(kali㉿kali)-[~]  
$ telnet 31.214.178.4 80  
Trying 31.214.178.4 ...  
Connected to 31.214.178.4.  
Escape character is '^]'.  
HEAD / HTTP/1.0  
  
HTTP/1.1 200 OK  
Date: Tue, 17 Feb 2026 19:32:27 GMT  
Server: Apache  
Upgrade: h2,h2c  
Connection: Upgrade, close  
Last-Modified: Mon, 12 Jan 2026 15:18:03 GMT  
ETag: "db5-648326199e2e7"  
Accept-Ranges: bytes  
Content-Length: 3509  
Vary: Accept-Encoding  
Content-Type: text/html  
  
Connection closed by foreign host.
```

Justificación: Estas herramientas manuales son fundamentales para evadir filtros que bloquean escaneos automáticos, permitiendo obtener la huella digital real del servidor.